

ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC BÁCH KHOA
KHOA KHOA HỌC VÀ KỸ THUẬT MÁY TÍNH



CO3084 - Mật mã học và Mã hóa Thông tin (TN)

Problem Set 3

Asymmetric Cryptography

SVTH: Nguyễn Tấn Tài - 2212990

TP. Hồ Chí Minh, Tháng 10/2025

Mục lục

1	Độ khó mật mã và các tác động trong thế giới thực	1
1.1	Phá vỡ mật mã: Các kịch bản tấn công (10 điểm)	1
1.1.1	Kịch bản “Tận thế mật mã” (5 điểm)	1
1.1.2	Vấn đề tham số Diffie–Hellman yếu (5 điểm)	1
1.2	Kiến trúc bảo mật logarit rời rạc (10 điểm)	1
1.2.1	Thảm họa tham số yếu (5 điểm)	1
1.2.2	Phân tích đánh đổi giữa Elliptic Curve và Trường hữu hạn (5 điểm)	1
2	Diffie–Hellman trong môi trường thù địch	2
2.1	Các kịch bản tấn công và phòng thủ (10 điểm)	2
2.1.1	Kẻ trung gian hoàn hảo (Perfect Man-in-the-Middle) (5 điểm)	2
2.1.2	Kịch bản “người tố giác hoang tưởng” (5 điểm)	2
2.2	Thử thách thiết kế giao thức (10 điểm)	2
2.2.1	Phân tích SSH Trust-on-First-Use (TOFU)	2
3	Kỹ thuật bảo mật đường cong elliptic	3
3.1	Lựa chọn đường cong dưới áp lực (15 điểm)	3
3.1.1	Tranh cãi về “cửa hậu chính phủ” (8 điểm)	3
3.1.2	Kịch bản tấn công “đường cong không hợp lệ” (7 điểm)	3
3.2	Phân tích lỗ hổng triển khai (15 điểm)	3
3.2.1	Phòng thí nghiệm tấn công kênh kề (Side-Channel Attack) (8 điểm)	3
3.2.2	Khủng hoảng xác thực Ed25519 (7 điểm)	3
4	Nghiên cứu tình huống về mật mã ứng dụng	4
4.1	Phân tích lược đồ chữ ký trong tiền điện tử (15 điểm)	4
4.2	Thiết kế hệ thống liên lạc bảo mật (15 điểm)	4

1 Độ khó mật mã và các tác động trong thế giới thực

1.1 Phá vỡ mật mã: Các kịch bản tấn công (10 điểm)

1.1.1 Kịch bản “Tận thế mật mã” (5 điểm)

Hãy tưởng tượng bạn thức dậy và thấy dòng tít báo lớn:

“Thuật toán đột phá chứng minh $P = NP$ – Các nhà khoa học máy tính xác nhận!”

- Với tư cách Giám đốc an ninh thông tin (CSO) của một ngân hàng lớn, hãy viết bản ghi nhớ ứng phó khủng hoảng, mô tả những hệ thống nào sẽ sụp đổ ngay lập tức, và bạn sẽ triển khai những biện pháp khẩn cấp nào.
- Hãy thiết kế mô hình bảo mật thay thế cho ngân hàng trực tuyến trong thế giới hậu $P = NP$. Bạn sẽ dựa vào các giả định nào khác để đảm bảo an toàn?

1.1.2 Vấn đề tham số Diffie–Hellman yếu (5 điểm)

Một nhà nghiên cứu bảo mật phát hiện rằng một thư viện mật mã phổ biến tạo tham số Diffie–Hellman trong đó số nguyên tố p thỏa mãn $p - 1$ có nhiều ước nhỏ, khiến 75% nhóm sinh ra dễ bị tấn công Pohlig–Hellman.

- Hãy đánh giá xem phát hiện này có làm sụp đổ hoàn toàn Diffie–Hellman hay chỉ làm suy yếu một phần. Cần phân tích cả khía cạnh toán học lẫn tác động triển khai thực tế.
- Đề xuất chiến lược ứng phó cho các hệ thống đang dùng thư viện này: có nên tái sinh toàn bộ tham số, thêm bước kiểm tra hợp lệ, hay chọn cách tiếp cận khác?

1.2 Kiến trúc bảo mật logarit rời rạc (10 điểm)

1.2.1 Thảm họa tham số yếu (5 điểm)

Cuộc kiểm toán an ninh phát hiện hệ thống kế thừa đang sử dụng tham số cho trao đổi khóa Diffie–Hellman:

$$p = 2047 = 23 \times 89, \quad g = 2.$$

- Phân tích chi tiết tại sao lựa chọn này cực kỳ yếu. Ước lượng thời gian tấn công cần thiết cho một kẻ tấn công chỉ dùng máy tính xách tay hiện đại.
- Thiết kế kế hoạch ứng phó khẩn cấp: làm sao chuyển người dùng sang tham số an toàn hơn mà vẫn duy trì dịch vụ liên tục?

1.2.2 Phân tích đánh đổi giữa Elliptic Curve và Trường hữu hạn (5 điểm)

Bạn đang thiết kế giao thức mật mã cho thiết bị IoT có hạn chế nghiêm trọng về tính toán và băng thông.

- So sánh logarit rời rạc trên đường cong elliptic (ECDLP) và trên trường hữu hạn (DLP) cho trường hợp này: loại nào an toàn hơn trên mỗi bit khóa, loại nào hiệu quả tính toán hơn?
- Giải thích tại sao tấn công Index Calculus hoạt động được với trường hữu hạn nhưng không áp dụng cho elliptic curve. Sự khác biệt này ảnh hưởng thế nào đến biên độ an toàn?

2 Diffie–Hellman trong môi trường thù địch

2.1 Các kịch bản tấn công và phòng thủ (10 điểm)

2.1.1 Kẻ trung gian hoàn hảo (Perfect Man-in-the-Middle) (5 điểm)

Kẻ tấn công kiểm soát hoàn toàn mạng giữa Alice và Bob, có thể chỉnh sửa mọi thông điệp và giả mạo kết nối từ bất kỳ bên nào.

- Thiết kế cuộc tấn công trung gian hiệu quả nhất vào Diffie–Hellman không xác thực, sao cho Alice và Bob không thể phát hiện trong quá trình trao đổi khóa.
- Giả sử Alice và Bob chưa từng gặp nhau, nhưng mỗi người có dấu vân tay khóa công khai của người kia ghi trên giấy. Hãy thiết kế giao thức xác thực đánh bại tấn công trên, chỉ sử dụng các dấu vân tay này.
- So sánh phương pháp dùng dấu vân tay với mô hình cơ quan chứng thực (CA) và web-of-trust. Phân tích sự đánh đổi giữa tính tiện dụng và an toàn.

2.1.2 Kịch bản “người tổ giác hoang tưởng” (5 điểm)

Một người tổ giác cần liên lạc bảo mật với nhà báo. Họ tin rằng chính phủ giám sát toàn bộ Internet, đã xâm nhập hầu hết CA, và có thể thực hiện MITM trên mọi kết nối.

- Thiết kế giao thức trao đổi khóa phù hợp trong bối cảnh này, chỉ dùng công cụ mà người dân bình thường có thể tiếp cận (không phần cứng chuyên dụng, không bí mật chia sẻ trước).
- Phân tích nếu chính phủ chiếm được thiết bị của một bên sau khi trao đổi khóa, làm thế nào để duy trì bí mật chuyển tiếp (forward secrecy)?

2.2 Thử thách thiết kế giao thức (10 điểm)

2.2.1 Phân tích SSH Trust-on-First-Use (TOFU)

Tổ chức của bạn triển khai SSH trên 10.000 máy chủ, nhưng mô hình TOFU hiện tại gây ra vấn đề về bảo mật và khả năng sử dụng.

- (5 điểm) Phân tích các kịch bản tấn công cụ thể khiến mô hình TOFU thất bại. Khi nào người dùng dễ bị tấn công nhất?
- (5 điểm) Thiết kế mô hình xác thực cải tiến vẫn giữ đơn giản như SSH, nhưng đảm bảo an toàn hơn TOFU thuần túy.

3 Kỹ thuật bảo mật đường cong elliptic

3.1 Lựa chọn đường cong dưới áp lực (15 điểm)

3.1.1 Tranh cãi về “cửa hậu chính phủ” (8 điểm)

Bạn là kiến trúc sư bảo mật cho một ứng dụng nhắn tin mới. Giới mật mã đang tranh luận liệu NIST P-256 có cửa hậu của chính phủ hay không, trong khi Curve25519 được xem là an toàn hơn nhưng ít được phần cứng hỗ trợ.

- Phân tích các mối lo ngại cụ thể về NIST curve: cửa hậu trông như thế nào, và có thể bị khai thác ra sao mà không phá vỡ hoàn toàn vấn đề toán học nền tảng?
- Thiết kế khung đánh giá rủi ro để chọn giữa P-256 và Curve25519. Những yếu tố nào nên ảnh hưởng đến quyết định?
- Đội pháp lý báo cáo rằng một số quốc gia yêu cầu chuẩn NIST cho các sản phẩm bán cho chính phủ. Hãy đề xuất giải pháp dung hòa giữa lo ngại cửa hậu và yêu cầu tuân thủ.

3.1.2 Kịch bản tấn công “đường cong không hợp lệ” (7 điểm)

Một nhà nghiên cứu phát hiện triển khai ECDH của bạn không kiểm tra hợp lệ điểm đầu vào, khiến nó dễ bị tấn công Invalid Curve.

- Thiết kế cuộc tấn công cụ thể khai thác lỗ hổng này. Kẻ tấn công có thể thu được thông tin gì?
- Phát triển chiến lược kiểm tra đầu vào toàn diện để ngăn lớp tấn công này. Phân tích tác động hiệu năng của giải pháp.

3.2 Phân tích lỗ hổng triển khai (15 điểm)

3.2.1 Phòng thí nghiệm tấn công kênh kề (Side-Channel Attack) (8 điểm)

Bạn được giao nhiệm vụ kiểm thử thiết bị nhúng có triển khai ECDSA nhằm phát hiện lỗ hổng kênh kề.

- Thiết kế tấn công thời gian (timing attack) đối với ECDSA. Bạn có thể phân biệt hai thao tác nào?
- Phát triển các biện pháp đối phó duy trì hiệu năng mà chống được tấn công. Bạn sẽ triển khai kỹ thuật tính toán thời gian hằng (constant-time) nào?

3.2.2 Khủng hoảng xác thực Ed25519 (7 điểm)

Bạn phát hiện rằng hai thư viện Ed25519 phổ biến chấp nhận các chữ ký khác nhau là hợp lệ cho cùng một thông điệp và khóa công khai, dẫn đến mất khả năng tương tác.

- Điều tra nguyên nhân sự khác biệt: bước xác thực nào mỗi thư viện xử lý khác nhau?
- Phân tích hệ quả bảo mật: liệu kẻ tấn công có thể lợi dụng sự khác biệt này để thực hiện tấn công thực tế?

4 Nghiên cứu tình huống về mật mã ứng dụng

4.1 Phân tích lược đồ chữ ký trong tiền điện tử (15 điểm)

Một dự án tiền mã hóa mới cần chọn giữa ECDSA và Ed25519 cho chữ ký giao dịch. Yêu cầu hệ thống gồm:

- Tốc độ xử lý cao (hàng nghìn chữ ký mỗi giây)
- Bảo mật lâu dài (an toàn hàng thập kỷ)
- Tương thích với ví phần cứng và thiết bị di động
- Ký giao dịch theo cách xác định (deterministic) để dễ tái lập

Hãy phân tích và trả lời:

- (5 điểm) So sánh ECDSA và Ed25519 theo từng tiêu chí trên. Thuật toán nào phù hợp hơn, và vì sao?
- (5 điểm) Thảo luận tác động của tính biến dạng chữ ký (signature malleability). Điều này ảnh hưởng ra sao đến mỗi thuật toán, và vì sao nó quan trọng với tiền điện tử?
- (5 điểm) Đưa ra khuyến nghị cuối cùng có giải thích rõ ràng, cân nhắc cả kỹ thuật lẫn thực tiễn.

4.2 Thiết kế hệ thống liên lạc bảo mật (15 điểm)

Bạn được giao kiến trúc hệ thống liên lạc an toàn cho tổ chức có trên 10.000 nhân viên, phải chống cả tấn công bên ngoài lẫn nội gián, hỗ trợ:

- Nhắn tin thời gian thực
- Chia sẻ tệp
- Cuộc gọi thoại

Hãy thiết kế và phân tích giải pháp hoàn chỉnh:

- (5 điểm) Xác định thuật toán mật mã bạn chọn cho từng thành phần:
 - Giao thức trao đổi khóa
 - Lược đồ chữ ký số
 - Thuật toán mã hóa đối xứng
 - Hàm băm và MAC
- (5 điểm) Mô tả kiến trúc quản lý khóa: cách khởi tạo tin cậy, phân phối khóa, và xoay vòng khóa.
- (5 điểm) Phân tích tính bảo mật của hệ thống trước các kịch bản tấn công:
 - Nghe lén mạng
 - Máy chủ bị xâm nhập
 - Thiết bị người dùng bị chiếm quyền
 - Nội gián trong tổ chức